GHOSTWIRE

Threat intelligence, told as narrative.

#ISSUE 003 OCTOBER 2026

The Proxy in the File Manager

How a mainstream Android file manager shipped the Popa residential-proxy SDK

// INTELLIGENCE FILE — GW-003-INF //

SUBJECT:	**io.nn.alpha (“Alpha”) residential-proxy SDK**
CARRIER:	**X-Plore File Manager (com.lonelycatgames.Xplore)**
FAMILY:	**Popa / NetNut — Alarum Technologies**
SAMPLE:	**libnativesdk.so — arm64, X-Plore 4.43.10**
PRESENT:	**Sep 2024 to 4.43.14, removed by 4.44.00**
STATUS:	**network FBI-seized July 2026**

8	7	~9	100M+
SDK DOMAINS	C2 COMMANDS	MO. RESIDENT	INSTALL APP

For roughly nine months, X-Plore, a long-established Android file manager with a very large install base, shipped a hidden residential-proxy module that enrolls the device as an exit node for third-party traffic. It is the “Alpha” variant of the Popa family that Synthient, Qurium and XLab tie to the proxy provider NetNut. The variant and its domains are already public; what is new here is the carrier, and a sample dating to September 2024, about 17 months before the earliest native-generation sample previously on record.

The story: who / what / where / when / why

X-Plore is the kind of app that sits quietly on millions of phones for years. For about nine months of its release history, some of those installs also carried a second, unadvertised job: lending out the phone's internet connection.

Buried in the app was a module, `io.nn.alpha`, that on command would turn the device into a **residential proxy**, a relay that routes someone else's web traffic out through the user's home IP address. Residential proxies are sold commercially because traffic from a real consumer IP is far harder for websites to block than traffic from a data center. The people buying that access get a clean-looking exit point. The person who owns the phone gets nothing, and in most cases has no idea it is happening.

The proxyware itself is not new. Researchers at Synthient, Qurium and XLab have documented this family, called "Popa," and traced it to a residential-proxy provider, NetNut (parent company Alarum Technologies, which is publicly traded). They have named the "Alpha" label and the relay domains. What none of them named is **where this build was riding**: X-Plore, a mainstream file manager, not the obscure streaming and TV-box apps the prior reports focused on. And the build we pulled apart dates to **September 2024, about 17 months before the earliest sample of this native-code generation that Synthient placed on record.** It still carries a leftover `NEUPOP_LOCK` constant under its "Alpha" paint, which is the tell that ties it to the lineage.

It also behaves carefully: it does not simply switch on. It first phones a server and effectively asks permission, sending along enough about the device for the operator to decide whether that particular phone is worth using.

[working hypothesis] Whether X-Plore's developer knowingly bundled this, was paid to, or integrated a tainted advertising/monetization SDK without understanding it, is **not established by this analysis** and is not claimed here. The code is present in the public APKs; the intent behind its inclusion is a separate question.

Why you should care

If your phone is used as an exit node, **your IP address gets attached to strangers' traffic.** That can mean ad fraud, credential stuffing, scraping, or worse, all appearing to originate from your home connection. It burns your mobile data and battery, and it can land your IP on block lists. You did not meaningfully agree to any of it, and the server-side gate means you cannot even tell from the outside whether your specific device was switched on.

How else this could be leveraged

Two design choices here reach well past reselling bandwidth:

1. **The per-device gate is a targeting primitive.** A server that decides activation from the device's model, OS and region can just as easily select *only* phones in a chosen

country, on a chosen carrier, or of a chosen model. The same mechanism that quietly rations proxy load could quietly single out a population.

2. **A tunnel with no destination restriction beyond private ranges is a general-purpose "connect anywhere" capability.** Reselling exit bandwidth is the benign reading. The same primitive can reach any public host the operator names, which is a very different thing to have resident on millions of consumer devices.

PART II — TECHNICAL REPORT

SECTION 1

Background & scope

The sample surfaced during a static sweep for proxyware SDKs across Android file-manager builds. The `io.nn.*` namespace and a `libnativesdk.so` with a Popa-style configuration pointed at the Popa / Neupop family documented by Synthient, and by HUMAN's PROXYLIB research.

Scope. This report is **static analysis only**: `jadx` over the app's DEX and Ghidra over the native library `libnativesdk.so` (arm64-v8a, from X-Plore 4.43.10), cross-referenced with passive DNS, certificate transparency, RDAP and VirusTotal resolution history. No dynamic execution was performed; the host app is integrity-protected and the reasons are detailed under Limitations.

Analysis target: `libnativesdk.so` sha256 `0792897cec2a43eaa1f806e8e477f11aab73cccb6c91a8e03504ea78fd76f0ba`, NDK r25b / clang 14.0.6, stripped, BuildID `bddb8f4e2d49ffdd385e561ca5c8f6f91b3ba0a3`, build path `/opt/jenkins/workspace/gms_alpha/alphapop/src/main/cpp/mbed/`.

SECTION 2

Technical analysis

Family identification and placement. The package is `io.nn.alpha`, with Java classes `AlphaConfig`, `AlphaPop`, and `sdk_actions/AlphaSdkEngine`. [confirmed] Synthient's family table (Figure: Moneytiser `io.moneytise`, 2020-12; Popa `io.popanet`, 2022-03; Loopop `io.nn.lp`, 2023-11; Neupop `io.nn.neunative` / `io.nn.nativesdk`, C++, earliest 2026-02) does **not** list an "Alpha" entry, though Qurium and XLab name the Alpha variant (`libalphasdk`) and the relay domains separately. Our sample is the **same C++ native generation as Synthient's "Neupop"** (a `libnativesdk.so`, not the earlier Java builds), which places it at the leading edge of the family's move to native code. The significant point is the date: this build ships in X-Plore from **September 2024**, roughly **17 months earlier than the 2026-02 earliest-sample date Synthient assigns that native generation**. [confirmed, from AndroZoo build dates] The strongest lineage tell is an incomplete rebrand: the module binds a system-wide `LocalServerSocket` named **`NEUPOP_LOCK`** (`p053e8/f.java:25`, bound at `e.java:29`), while every log tag in the same code path reads **`AlphaSocketLock`**. [confirmed] The cosmetic strings were renamed to "Alpha"; the functional singleton-lock constant was not. A uniqueness sweep of 169 builds across 28 other packages found `io.nn.alpha` in none of them; X-Plore is the only observed carrier, and no prior public report names it. [confirmed]

Two-stage bootstrap and the device gate. [confirmed] Before the proxy runs, `T2/d.java` + `T2/a.java` perform a device-compatibility check: an HTTPS GET to `https://lb.<domain>/initreq/?os=android&ver=<sdkver>&manufactor=<mfr>&model=<model>`, per domain, 3s timeout, 5 retries, then the next domain. The SharedPreference `init_allowed` is set true **only if the**

response body contains the string `YES`; otherwise the SDK refuses to start (`p011b/d.java`, the `init_allowed` check gates the start path). The server decides per device whether to activate.

Configuration scheme (shared with Popa). [confirmed] The domain list has a hardcoded fallback (`p053e8.c.f50713a`) and a refreshable source. The refresh (`DomainsProvider`, native; and `T2/a.b()`, Java) fetches an encrypted blob, decrypts it with **AES-128 / key `eeorahrabcap286!`**, and splits the plaintext on commas. The native side's config object is the Google Drive URL `hxxps://drive[.]google[.]com/uc?export=download&id=1K95AXo75gi-jJSE9vuVPVEyBya0JUm0w`. Synthient documents the **same Drive ID and the same key** for Popa (Popa.md row 54), decrypting to `gmslb[.]net, fast-mob[.]com, sdkmob[.]org, swift-zip[.]com`. [confirmed] Java and native share the key and format.

Registration and what leaves the device. [confirmed] After the load balancer returns peer servers, the SDK opens a TLS connection to a control server and sends a Register message in a custom TLV wire protocol (4-byte type + 4-byte length header, big-endian integers). The fields:

TLV	Field	TLV	Field
`0x6050`	uuid (random v4, persisted)	`0x6058`	wifi flag
`0x6051`	dev_country	`0x6059`	model
`0x6052`	dev_city	`0x605a`	net_type
`0x6053`	publisher	`0x605b`	sdk_int
`0x6054`	sdk_version	`0x605c`	`{"extra":..,"packageName":"<host app>"}`
`0x6055`	dev_asn	`0x605d`	(registered, never set)
`0x6056`	carrier	`0x605e`	constant `1`
`0x6057`	dev_state		

The geo fields (`country/state/city/asn`) are supplied by the load balancer's JSON reply and echoed back; the load balancer geolocates the device from the connection and the phone reports it onward. The **host application's package name travels in TLV `0x605c`** on every registration, confirmed from Java (`AlphaSdkEngine.startSdk1` passes `getPackageName()`) through to the native serializer.

Command set. [confirmed] The message decoder accepts exactly seven server-to-client types; anything else logs `Got invalid message` and disconnects:

Type	Message	Action
`0x5060`	Register	no-op
`0x7070`	RegisterResponse	mark registered
`0x9010`	Ping	reply Pong
`0xa070`	OpenTunnel(id, host, port)	open TCP tunnel
`0xc000`	Tunnel data	forward to tunnel
`0xcccc`	CloseTunnel(id)	close tunnel
`0xdddd`	Goodbye	`Engine::stop` (remote kill)

The tunnel. [confirmed] `OpenTunnel` carries three TLVs: tunnel id (ulong), host (char*), port (int). The path is `TunnelManager::openTunnel` -> `new Tunnel` -> `NetworkHandler::connect` -> `DnsResolver::resolveHost` -> `socket(AF_INET, SOCK_STREAM | SOCK_NONBLOCK)` + `connect()`. The phone connects wherever the server names, IPv4 TCP only. The **one destination restriction** is in `DnsResolver::processRequest`: it takes the first `AF_INET` result and fails the lookup if `Utils::isLocalAddress()` is true, covering `10/8, 172.16/12, 127/8, 192.168/16, 169.254/16, 224/3`. [confirmed] Not covered: `0/8, 100.64/10` (CGNAT), `198.18/15, 192.0.0/24`. No port restriction anywhere. Tunnel payloads are plain TCP (not TLS); the control channel is TLS.

TLS posture. [confirmed] mbedTLS 3.4.0, statically linked. The certificate chain is validated against the system CA store, but `mbedtls_ssl_set_hostname` has **no callers**, so there is no hostname/SAN check on the load balancer, control server or Drive connections. Any certificate chaining to a system-trusted CA is accepted.

Resilience and stealth. [confirmed] A `BOOT_COMPLETED` receiver and `START_REDELIVER_INTENT` keep the foreground service (`dataSync` type) alive; on API >= 34 a caught `ForegroundServiceStartNotAllowedException` defers the start until the host app is foregrounded. A crash handler (`sigaction` on SEGV/ABRT/BUS) reports the crash to the control server as a StatusUpdate (TLV `0x1112`: uptime, signal, publisher, version, OS, device, backtrace) and then `siglongjmp`s back into the worker loop rather than dying. A 60-second bandwidth meter stops the SDK once usage exceeds a server-set cap.

SECTION 3

Infrastructure & pivots

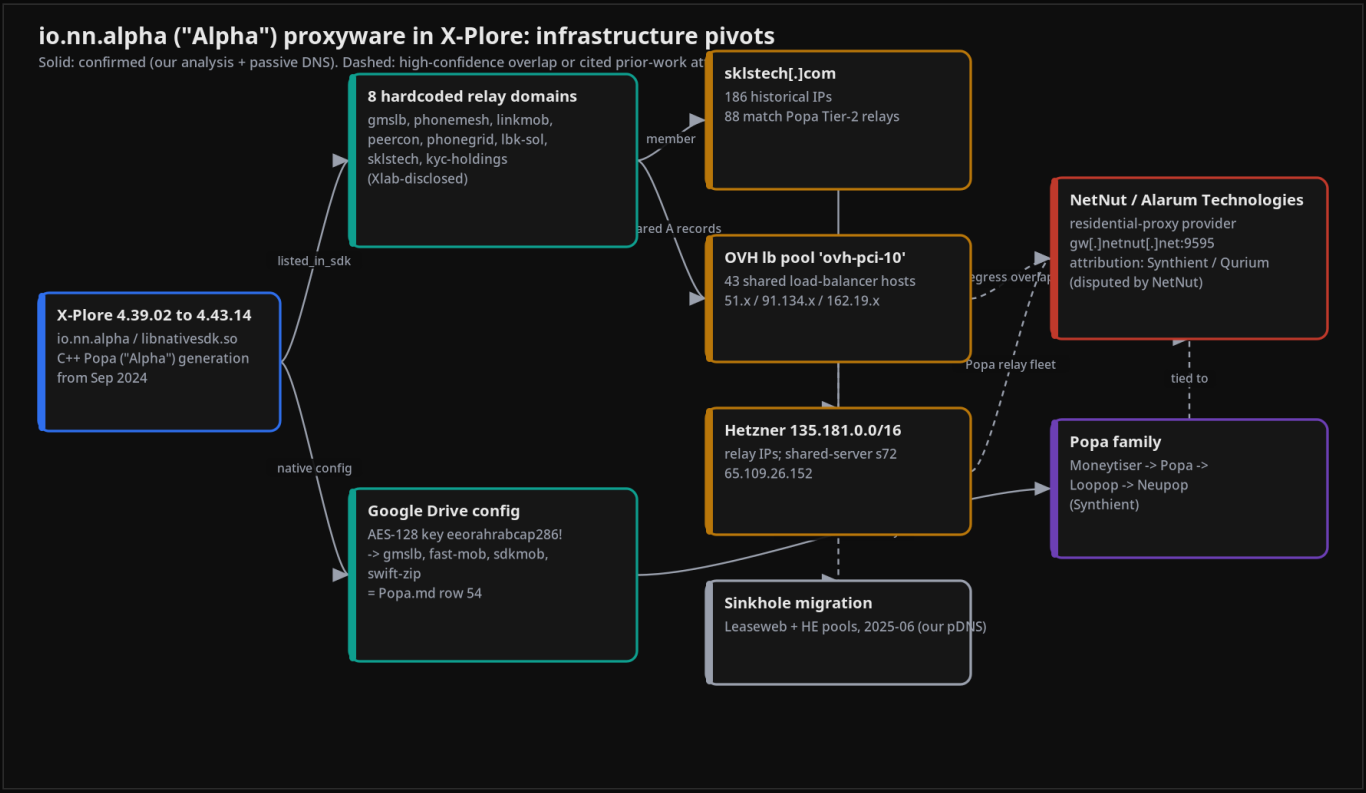


Figure 1. Pivot graph. Solid edges are confirmed from our static analysis and passive DNS; dashed edges are high-confidence infrastructure overlap or attribution cited from prior work (Synthient, Qurium). SVG and PNG in this issue's folder.

Eight domains are hardcoded in the SDK (`p053e8.c.f50713a`); three more come from the Popa Drive config.

Indicator	Pivot type	Linked to	Confidence	Evidence
`sklstech[.]com`	DNS / relay pool	Popa Tier-2 relays	high	186 historical IPs; 88 match Synthient Popa Tier-2
`lb.<domain>` pool	shared A records	43-IP OVH LB pool	high	`ovh-pci-10` pool shared across 43 tracked hosts
`65.109.26.152`	shared server	second SDK domain	high	`same_server_number` s72, Hetzner
`gmslb[.]net`	Drive config	Synthient Popa (row 54)	confirmed	same Drive ID + AES key
OVH + Hetzner relays	ASN / hosting	Popa fleet	high	`135.181.0.0/16` (Hetzner), OVH PCI ranges
sinkhole migration	takedown	Popa cluster	high	relays moved to Leaseweb + HE pools by 2025-06 (our pDNS); NetNut network FBI-seized Jul 2026

SECTION 4

Comparison to prior campaigns, and what is new here

The family is Popa, documented by Synthient ("Popa: From Sourcing to Distribution," June 2026), Qurium ("Finding Popa"), and XLab, and it fits HUMAN Security's broader PROXYLIB pattern of SDK-delivered residential proxyware. Synthient ties the family (Moneytiser, Popa, Loopop, Neupop) to the residential-proxy provider **NetNut**, whose parent **Alarum Technologies Ltd** is publicly traded; a controlled Synthient test on 2026-06-17 observed traffic from a Popa-enrolled host egressing through NetNut's commercial gateway (`gw[.]netnut[.]net:9595`, path `/NETNUT_EXT_TRAFFIC_FROM_PROXY`). Qurium links the **NinjaTech** platform (`ninjatech[.]io`, registered 2020-01-29) to NetNut leadership from public business records, and XLab connects the family to the **Vo1d** Android-TV botnet. NetNut/Alarum dispute these characterizations. In July 2026 the FBI, with Shadowserver, Google and Lumen, seized the NetNut network and hundreds of associated domains. None of this attribution or takedown is our work; it is cited.

What this report corroborates (so it is confirmation, not discovery): the `/initreq` `YES`/`NO` device gate, the `lb.<domain>:5002/devicereg` registration, the `s0` and `sXXXX.byte-buff[.]com:6000` relay naming, and the AES Google-Drive config scheme all appear in Synthient's analysis of other samples. Our independent static read reaching the same mechanisms is useful cross-validation.

What is new here: 1. **The carrier.** X-Plore, a mainstream file manager, is a carrier no prior report names; earlier work focused on streaming, IPTV and TV-box apps. 2. **An earlier native-generation sample.** Our `io.nn.alpha` is the C++ generation Synthient calls "Neupop," but ships from September 2024, roughly 17 months before the 2026-02 date Synthient assigns that generation. It pushes the family's native-code timeline back and shows the `NEUPOP_LOCK`-under-"Alpha" transitional state directly. 3. **Native-protocol depth.** The full seven-type command set including the remote `Goodbye` kill, the `OpenTunnel` connect-anywhere path with its single private-range filter, the complete Register TLV map, and the `mbedtls_ssl_set_hostname`-has-no-callers finding are documented here from the binary. 4. **A distinct publisher config instance.** Our Drive object and key (`eeorahrabcap286!`, Popa.md row 54) differ from the sample in Synthient's writeup (`venlutDakros643!`), evidence of a separate publisher branch. 5. **Tested detection** keyed on the native library and network behavior, with the pairip-encrypted-DEX caveat spelled out.

Version timeline (AndroZoo-bracketed, adjacent builds). [confirmed] Introduced between X-Plore 4.38.40 (2024-09-04, clean) and 4.39.02 (2024-09-22): an 18-day window. The `io.nn.alpha` label was swapped for `io.nn.neun`/`neunative` between 4.43.10 (2025-06-14) and 4.43.14 (2025-06-18). Gone entirely by 4.44.00 (2025-07-01). Total presence roughly nine months. An independent hash scan of the `libnativesdk.so` across local builds corroborates: present 4.40.01 through 4.43.14, absent 4.44.00 onward.

SECTION 5

IOC reference

Type	Indicator	Note
domain	`gmslb[.]net`	SDK + Popa Drive config (row 54)
domain	`phonemesh[.]org`	SDK hardcoded
domain	`linkmob[.]org`	SDK hardcoded
domain	`peercon[.]org`	SDK hardcoded
domain	`phonegrid[.]org`	SDK hardcoded
domain	`lbk-sol[.]com`	SDK hardcoded
domain	`sklstech[.]com`	SDK hardcoded; 186-IP relay history
domain	`kyc-holdings[.]com`	SDK hardcoded
domain	`fast-mob[.]com`	Popa Drive config (candidate)
domain	`sdkmob[.]org`	Popa Drive config (candidate)
domain	`swift-zip[.]com`	Popa Drive config (candidate)
url	`hxxps://drive[.]google[.]com/uc?export=download&id=1K95AXo75gi-jJSE9vuVPVEyBya0JUm0w`	encrypted domain config
key	`eeorahrabcap286!`	AES-128 config key (shared with Popa)
sha256	`0792897cec2a43eaa1f806e8e477f11aab73cccb6c91a8e03504ea78fd76f0ba`	`libnativesdk.so` (arm64, X-Plore 4.43.10)
buildid	`bddb8f4e2d49ffdd385e561ca5c8f6f91b3ba0a3`	native library BuildID
package	`io.nn.alpha`	SDK package namespace
socket	`NEUPOP_LOCK`	LocalServerSocket name (lineage tell)

SECTION 6

Detection

Three rules, all validated (YARA compiles clean and matches the sample while staying silent on unrelated binaries; Sigma parses against the current schema). Rule files ship alongside this issue in `detections/`.

Where detection is and is not possible. The shipped APK is pairip-wrapped: its real DEX, the `io.nn.alpha` classes included, lives in encrypted asset blobs (randomly-named ~120KB

files under `assets/`) that the native VM decrypts at runtime. So `io.nn.alpha`, `NEUPOP_LOCK` and the `/initreq` template are **not present as plaintext in the distributed APK**, and DEX string-scanning will miss them. Reliable detection keys on the native library (plaintext, loaded normally from `lib/`) and on network telemetry. A DEX rule is provided for analysts working from a decrypted or dumped DEX.

1. Native library (primary file signature), validated.

```
rule proxyware_io_nn_alpha_native
{
    meta:
        description = "io.nn.alpha residential-proxy native SDK (libnativesdk.so), Popa/Neupop
lineage"
        author = "Bornov Shyam Kalita"
        date = "2026-10-16"
        reference = "GhostWire Issue 003 (2026-BSK-003)"
        hash = "0792897cec2a43eaa1f806e8e477f11aab73cccb6c91a8e03504ea78fd76f0ba"
        confidence = "high-confidence: build path and JNI symbol are alpha-specific; the AES key is
shared across the Popa family so it broadens to the family, not just this variant"
    strings:
        $build = "/opt/jenkins/workspace/gms_alpha/alphapop/src/main/cpp/mbed/" ascii
        $jni   = "Java_io_nn_alpha_sdk_1actions_AlphaSdkEngine_" ascii
        $key   = "eeorahrabcap286!" ascii
        $c1 = "LBConnectionHandler" ascii
        $c2 = "DomainsProvider" ascii
        $c3 = "Alpha_SDK" ascii
        $c4 = "SdkProtocolOpenTunnelMessage" ascii
    condition:
        uint32(0) == 0x464c457f and filesize < 8MB and
        ( $build or $jni or ( $key and 2 of ($c*) ) )
}
```

2. Network beacon (packing-agnostic, runtime), validated. Sigma keying on the per-device `/initreq` gate. Full rule in `detections/alpha_beacon.sigma.yml`; condition: `selection_uri and (selection_ua or selection_host)`, matching a GET to `/initreq` carrying `os=android` + `manufactor=` + `model=`, with User-Agent `SDK` or a `lb.` host prefix. A companion DNS rule should alert on resolution of the eight hardcoded relay domains (see IOC table).

3. Decrypted DEX only (scoped), validated-compiles. `detections/alpha_dex_decrypted.yar` keys on `io/nn/alpha`, the `AlphaService` class, `NEUPOP_LOCK`, and the `/initreq` template. Its meta states plainly that it does **not** match the shipped pairip-wrapped APK and is only for a decrypted or dumped DEX.

SECTION 7

Limitations

- **No dynamic validation.** This is static analysis. The host app (X-Plore 4.43.10) is wrapped with Google Play Automatic Integrity Protection (pairip): the real DEX runs through a native VM decrypted into anonymous memory, plus an APK signature check. On an x86_64 emulator with arm64 translation the process SIGSEGVs at launch, and current Android emulators no longer emulate arm64 on x86 hosts. Confirming the connect-anywhere tunnel behavior live, observing real control-server traffic, and recovering the runtime-decrypted init URL all require a **native arm64 instrumentation platform (for example Corellium) or a dedicated rooted arm64 device**, plus handling of the pairip layer. This is the single largest gap and the natural next phase.
- **Server-side behavior is unknown.** The client capabilities are confirmed from the binary; what the operator actually does with them (which destinations, which devices selected by the `/initreq` gate) cannot be determined from the client alone.
- **One inferred direction.** `TunnelManager::sendToTunnel` (server-to-destination path) is named but its body was not fully traced; the direction is inferred from the symbol. [high-confidence, not confirmed]
- **Config contents not independently decrypted.** The Drive config plaintext (`gmslb[.]net, fast-mob[.]com, sdkmob[.]org, swift-zip[.]com`) is per Synthient; it was not fetched or decrypted here by design (the live object was deliberately not pulled).
- **Obfuscated init URL.** The Java config-fetch URL is runtime-decrypted via a string-obfuscation shell (`p077h.LOj`) and was not recoverable from `jadx` alone.
- **Attribution is prior work's, not ours.** The link from this family to NetNut / Alarum Technologies / the NinjaTech platform is established by Synthient and Qurium from network telemetry and public business records, and is disputed by NetNut. This report does not independently verify that linkage. What a planned addendum (Issue 003a) would add is tying X-Plore's specific relay cluster to that documented operation, not fresh corporate attribution.
- **Novelty scope.** "No public report names X-Plore as a carrier" rests on Qurium, Synthient and open search; I could not read XLab's original disclosure in full, so there is a residual chance the carrier is named in a source not reviewed here.

SECTION 8

References

1. Synthient, "Popa: From Sourcing to Distribution," June 2026. https://synthient.com/blog/popa-from-sourcing-to-distribution (family table, the `/initreq` gate, the NetNut/Alarum attribution and controlled egress test).
2. Qurium Media Foundation, "Finding Popa." https://www.qurium.org/forensics/finding-popa/ (names the Alpha variant / `libalphasdk` and the relay domains; NinjaTech-to-NetNut business-record linkage).
3. HUMAN Security (Satori Threat Intelligence), "PROXYLIB and LumiApps transform mobile devices into proxy nodes," March 2024. https://www.humansecurity.com/learn/blog/

satori-threat-intelligence-alert-proxylib-and-lumiapps-transform-mobile-devices-into-proxy-nodes

4. AndroZoo, University of Luxembourg. https://androzoo.uni.lu (build archive used for the version bracketing).
5. KrebsOnSecurity, "'Popa' Botnet Linked to Publicly-Traded Israeli Firm" (June 2026) and "FBI Seizes NetNut Proxy Platform, Popa Botnet" (July 2026). https://krebsonsecurity.com/tag/popa-botnet/ ; https://krebsonsecurity.com/2026/07/fbi-seizes-netnut-proxy-platform-popa-botnet/
6. XLab (QiAnXin), "Long Live The Vo1d Botnet," identifying the Mzmess/Popa proxy plugin inside the Vo1d Android-TV botnet. https://blog.xlab.qianxin.com/long-live-the-vo1d_botnet/
7. FBI / Shadowserver / Google / Lumen seizure of the NetNut network and the Popa cluster, July 2026 (Shadowserver assisted with sinkholing and notification). https://www.infosecurity-magazine.com/news/fbi-google-take-down-netnut-proxy/ . Separately, our own passive-DNS pull shows the Alpha relay fleet migrating to Leaseweb/HE sinkhole pools by June 2025.